CLIENTLOCKER

Secure Client Document Management System

Project / Client	ClientLocker / Vaigai Vel & Associates
Client location	Madurai, Tamil Nadu
Internship	Vizdale Full-Stack Developer Internship
Project period	1–30 November 2026
Document	M1 – Project Plan
Version	1.0 | 11 November 2026

Purpose
This plan defines the problem, proposed solution, users, technology choices, high-level architecture, milestones and expected outcome for the ClientLocker project.

Prepared for the M1 project foundation milestone

1. Project Overview

ClientLocker is a private document-management platform proposed for Vaigai Vel & Associates, an accounting firm in Madurai. The firm has 2 partners, 6 staff members and 140 client businesses. The current shared-folder approach allows too many people to access client documents, creating a risk of confidential information being viewed or shared incorrectly.

The system will organize documents by client and enforce permissions according to each person's role and assigned client access. Partners will be able to manage staff access and review an activity log. Clients will be able to view their own files, and auditors will be limited to the two clients assigned to them.

2. Problem Statement

The accounting firm currently stores client documents in a shared Drive folder where users can access documents beyond their assigned responsibilities. The client brief describes an incident in which one client's bank statements were sent to another client, and a former staff member retained access after leaving the firm. The project must reduce these risks through private file storage, server-enforced authorization, access removal and activity tracking.

3. Proposed Solution

Build a web-based application that provides secure sign-in, client-specific document lists, controlled file uploads and openings, temporary download links, access management and an auditable activity log. At a later milestone, add password-free client magic links and an AI-assisted suggestion that matches an uploaded document to an open checklist item. A person must confirm the AI suggestion before the checklist item is marked complete.

4. Project Objectives

- Keep each client's documents separate and prevent unauthorized cross-client access.
- Provide role-based access for partners, staff, clients and auditors.
- Allow partners to grant and remove staff or auditor access.
- Store uploaded files privately and provide time-limited access links.
- Record uploads, file openings, blocked attempts and access changes in an activity log.
- Support client magic-link login and AI-assisted checklist suggestions in the planned M3 scope.

5. Users and Permissions

Role	Allowed actions	Restrictions
Partner	View all clients and files; grant or remove staff access; read the activity log.	No restrictions specified in the client brief.
Staff	View, upload and open files for assigned clients.	Cannot view other clients, read the activity log or change access.
Client	Log in and view/open their own files.	Cannot upload or view another client's information.
Auditor	From M3, view/open files for exactly two assigned clients.	Cannot upload or delete files or view other clients.

6. Proposed Technology Stack

The following stack is the project's proposed implementation choice. The client brief permits the team to choose its tools and does not mandate a specific framework or database.

Layer	Proposed technology	Purpose
Frontend	React.js	Role-specific web dashboards and document screens.
Backend	Python + FastAPI	API endpoints, authentication and server-side permission checks.
Database	PostgreSQL	Store users, clients, access assignments, file metadata, links and logs.
Authentication	JWT-based sessions (proposed)	Identify authenticated users and their server-side roles.
File storage	Private local storage for development	Store uploaded files outside public web folders.
AI integration	Gemini API (proposed)	Suggest a checklist item from readable first-page document text.
Testing	Pytest	Test API behavior and authorization rules.
Version control / CI	Git, GitHub and GitHub Actions	Track changes and run automated checks.

7. High-Level System Architecture

Browser (React) → **FastAPI backend** → **PostgreSQL database** and **private file storage**. The browser sends requests to the backend. The backend identifies the logged-in person, checks their role and client assignment, reads or updates database records, and serves a file only after authorization succeeds. The AI service is called by the backend for the checklist suggestion feature; secret keys remain on the server.

Core security principle

Authorization will be checked on the server for every endpoint that accesses a client or file. Frontend button visibility is not treated as a security control. Files will not be exposed through permanent public URLs. Secrets will not be placed in frontend code or committed to GitHub.

8. Main Data Areas

- **Firm and people:** the firm, user profiles, roles and login identity.
- **Clients and access:** client records and the staff/auditor-to-client access assignments.
- **Files and checklists:** file metadata and each client's required document checklist.
- **Download links:** short-lived tokens tied to a person and a file.
- **Activity log:** who performed an action, the related file when applicable, timestamp and whether it was blocked.

The detailed database fields and API endpoints will be implemented from the ClientLocker brief during development.

9. Milestones and Planned Work

Milestone	Planned work	Evidence / output
M1 – Foundation	Confirm project scope and stack; create repository and initial folder structure; add README; configure GitHub Actions; prepare this project plan.	GitHub repository, docs/PLAN.pdf and initial automated check.
M2 – Core application	Create tables and seed data; implement partner, staff and client email/password login; build private file upload, listing and opening.	Demonstration of staff login, client file upload and file opening; role login tests.
M3 – Security and advanced features	Enforce server-side client access; implement client magic links, expiring download links, access removal, activity log, auditor role and AI checklist suggestion.	Access-control code link, auditor test login and feature tests.
M4 – Final hand-in	Fix issues, complete README, prepare demonstration video and final hand-in materials.	Working final demo, README and project submission.

10. Security and Quality Considerations

- Check the authenticated user's identity and role on the server; do not trust role values sent by the browser.
- Check client access on every endpoint that touches a client or file, including direct URL requests.
- Accept only PDF, JPG and PNG uploads up to 4 MB, as specified in the brief.
- Keep uploaded files in private storage and deliver them only through the application's authorization checks.
- Generate download links that expire after 10 minutes and re-check current access whenever a link is opened.
- Record uploads, opens, blocked attempts and access changes. Activity-log rows must not be editable or deletable by users.
- Use made-up data only. Do not use real client documents or personal information.
- Tests must use saved sample responses and must not depend on live external AI, email or payment services.
- Keep API keys and other secrets on the server and out of GitHub.

11. Initial Test Plan

The implementation will include the 10 tests listed in the ClientLocker brief. The initial test coverage will verify:

- Assigned staff can list files; unassigned staff receive 403.
- A staff member cannot open another client's file through a pasted or previously generated link; the blocked attempt is logged.
- A client cannot list another client's files.
- An auditor can open files for an assigned client but receives 403 when attempting to upload.
- Expired download links are blocked.
- A previously created link is blocked after the user's client access is removed.
- Staff cannot read the activity log.
- Requests without a valid login receive 401.

12. Expected Outcomes

At completion, ClientLocker is expected to provide a working role-based document portal in which users see only the client records and files they are permitted to access. Partners will be able to manage assignments and review activity. The application will demonstrate that access removal takes effect on the next request and that old download links cannot bypass updated permissions. The M3 AI feature will assist with checklist matching while keeping final confirmation with a person.

13. Scope Boundaries

The project will use made-up sample records and documents. The brief does not require client/file deletion, file previews, folders, search, password reset or a polished design. These items are outside the planned core scope unless time permits and the required milestones are already complete.

14. Assumptions

- The system will be developed as a web application for the internship demonstration.
- The seed script will create one firm, two partners, six staff members and ten clients, rather than the client's full production-sized dataset.

- The proposed technology stack may be adjusted if implementation needs require it, while preserving all role and security rules in the client brief.

End of Project Plan